GUIA DE ENDPOINTS

Back-End • Seda e Couro

Referência prática para acessar a API, entender a sessão e o CSRF, comparar o modelo atual com Bearer e consultar os endpoints implementados.

Base local de exemplo
http://localhost:3333/api/v1

Escopo
Rotas montadas em **backend/server.ts** e seus contratos documentados em **docs/api.md**. A situação descrita é a observada no código em 02/11/2026.

Material acadêmico de apoio. “Administrador” e “Funcionário” correspondem aos perfis da aplicação.

1. Começando: sequência de chamadas

O prefixo de todas as rotas é /api/v1. Em cada chamada autenticada, mantenha o cookie sapataria.sid. Para toda gravação, envie também o token CSRF da sessão no cabeçalho X-CSRF-Token.

1) Verificar a API

```
GET /api/v1/health
```

Rota pública, sem consulta ao banco. Retorna HTTP 200 com **{"status":"ok","mensagem":"Servidor funcionando"}**.

2) Obter cookie de sessão e token CSRF

```
GET /api/v1/auth/csrf
```

Rota pública. Retorna **{"csrfToken":"..."}** e cria/usa um cookie de sessão. Salve os dois valores.

3) Entrar

```
POST /api/v1/auth/login
Content-Type: application/json
X-CSRF-Token: [token obtido]

{"usuario":"carlos.lima","senha":"senha cadastrada"}
```

No sucesso, retorna HTTP 200 com **dados** públicos do funcionário, um token CSRF renovado e um cookie de sessão novo. Atualize ambos no cliente. O usuário não diferencia maiúsculas/minúsculas; login por e-mail não é aceito.

4) Consultar identidade e operar

```
GET /api/v1/auth/me

POST /api/v1/clientes
X-CSRF-Token: [token atual]
Cookie: [sapataria.sid]
Content-Type: application/json
```

As leituras autenticadas precisam do cookie. Nas alterações, mantenha cookie e token atualizados. GET, HEAD e OPTIONS não são submetidos à verificação CSRF, embora a maioria das rotas GET exija sessão.

Limites observados: sessão absoluta de 8 horas; usuário inativo, sessão expirada ou versão de acesso invalidada recebe 401. Login inválido tem resposta uniforme e limites de tentativas.

2. CSRF e Bearer: o que muda

Como identifica	Cookie aponta para uma sessão guardada no servidor.	Cliente envia credencial no cabeçalho Authorization: Bearer ...
Envio pelo navegador	Cookie é enviado automaticamente conforme domínio e política do navegador.	Token só é enviado quando o cliente o inclui no cabeçalho.
Risco principal tratado	CSRF: site externo tentar usar automaticamente o cookie da vítima.	Reduz o CSRF clássico porque o navegador não anexa Authorization automaticamente.
Proteção / cuidado	Token aleatório da sessão, retornado pela API e conferido em X-CSRF-Token. Cookie HttpOnly, SameSite=Lax e Secure em produção.	Proteção contra CSRF não elimina risco de roubo/exposição do token, especialmente por XSS ou armazenamento inseguro.
Estado e revogação	Sessão PostgreSQL; desativação, mudança de perfil e senha invalidam sessões pela versão de acesso.	Depende de como tokens e expiração/revogação forem projetados. Tokens autossuficientes podem ser mais difíceis de revogar imediatamente.

Por que a escolha atual é adequada ao projeto: o servidor usa uma aplicação web com sessões em cookie, guarda as sessões no PostgreSQL e já invalida acessos quando o funcionário é desativado, muda de perfil ou troca a senha. Nesse desenho,

CSRF complementa o cookie que o navegador envia automaticamente, sem exigir que o front-end armazene e administre um token Bearer. A escolha é adequada à arquitetura existente; não significa que CSRF seja universalmente superior a Bearer. Bearer também seria válido se a equipe adotasse uma arquitetura de tokens e definisse armazenamento, expiração, renovação e revogação.

O token CSRF não substitui autenticação: ele prova que a gravação veio de um cliente que conhece o token daquela sessão. A identidade e as permissões continuam sendo conferidas pela sessão e pelo perfil.

3. Convenções de resposta e validação

A resposta típica de consulta é HTTP 200 com **{"dados": ...}**. Criações retornam normalmente 201; exclusões e ações sem corpo retornam 204. Erros seguem **{"erro":{"codigo":"...","mensagem":"..."}}**.

400	Corpo, campo, filtro, data, decimal ou ID inválido.
401	Sessão inexistente, expirada ou invalidada; credenciais inválidas no login.
403	Permissão insuficiente ou CSRF inválido.
404	Registro/indicador não encontrado.
409	Conflito de negócio, vínculo, estado, duplicidade ou saldo insuficiente.
413 / 429 / 500	Corpo grande demais / limite de tentativas / falha interna sem detalhes sensíveis.

A API rejeita campos não previstos em muitos corpos. Valores decimais devem usar ponto; valores monetários aceitam até duas casas. Quantidades de materiais podem ser fracionárias, enquanto produtos e itens vendidos são inteiros.

4. Catálogo de endpoints implementados

A tabela indica o acesso e o efeito principal. Salvo indicação em contrário, todas as rotas abaixo estão sob /api/v1. Rotas de alteração passam pela verificação CSRF; ela ignora métodos GET/HEAD/OPTIONS.

Autenticação e perfil

GET /auth/csrf	Público	Cria/recupera sessão e retorna csrfToken.
POST /auth/login	Público + CSRF	Corpo usuario e senha. 200 com dados e token renovado; 401 credenciais inválidas; 429 limite.
POST /auth/logout	CSRF	Sem corpo. Destrói sessão e cookie; 204.
GET /auth/me	Autenticado	Identidade própria sem hash/senha; 200.
PUT /auth/senha	Autenticado + CSRF	senha_atual, senha_nova, confirmar_senha_nova. 204, encerra sessões e exige novo login.

Clientes

GET /clientes	Autenticado	Lista clientes por ID; resposta {dados:[...]}.
GET /clientes/:id	Autenticado	Perfil do cliente; ID inválido 400, inexistente 404.
GET /clientes/:id/ordens-servico	Autenticado	OS daquele cliente e dados do responsável; lista vazia se não houver OS.
POST /clientes	Autenticado + CSRF	nome, telefone, cep, numero obrigatórios; cpf, email, observacoes opcionais. Cria: 201.
PUT /clientes/:id	Autenticado + CSRF	Mesmo corpo completo do cadastro; atualiza: 200.
DELETE /clientes/:id	Autenticado + CSRF	Sem corpo; 204 se sem OS vinculada, 409 se houver vínculo, 404 se ausente.

Valida CPF (11 dígitos e verificadores), telefone (11 dígitos), CEP (8 dígitos), e-mail básico e número como texto, por exemplo “123A” ou “S/N”. Campos extras são rejeitados.

Funcionários

GET /funcionarios	Administrador	Lista dados públicos; sem senha.
POST /funcionarios	Administrador + CSRF	Nome, usuário, e-mail, CPF, telefone, senha (15–128 caracteres) e perfil. ativo opcional, padrão true. 201; usuário duplicado 409.
GET /funcionarios/:id	Administrador ou próprio	Funcionário comum só consulta seu próprio ID; outro ID dá 403.
GET /funcionarios/:id/ordens-servico	Administrador ou próprio	OS sob responsabilidade do funcionário consultado.
PUT /funcionarios/:id	Administrador + CSRF	Edita nome, e-mail, CPF, telefone e exige senha_admin do administrador conectado.
PUT /funcionarios/:id/acesso	Administrador + CSRF	perfil e ativo. Ao desativar, exige senha_admin; autodesativação proibida.
POST /funcionarios/:id/desativar	Administrador + CSRF	Corpo senha_admin; desativa e preserva perfil/histórico.

Materiais, produtos, fornecedores e categorias

GET /materiais	Autenticado	Lista materiais com saldo.
GET /materiais/:id	Autenticado	Consulta material; inexistente 404.
POST /materiais	Autenticado + CSRF	nome, categoria, unidade, quantidade_minima, custo; fornecedores_ids opcional; quantidade_inicial opcional só no cadastro.
PUT /materiais/:id	Autenticado + CSRF	Corpo completo do cadastro, exceto quantidade_inicial; não altera saldo. Troca de unidade bloqueada com saldo/histórico.
DELETE /materiais/:id	Autenticado + CSRF	Só sem vínculos e com saldo zero; caso contrário 409.
GET /produtos	Autenticado	Lista produtos para venda e saldos.
GET /produtos/:id	Autenticado	Consulta produto; inexistente 404.
POST /produtos	Autenticado + CSRF	nome, categoria, quantidade_minima, preco_custo, preco_venda; fornecedores_ids e quantidade_inicial opcionais.
PUT /produtos/:id	Autenticado + CSRF	Atualiza cadastro, sem mudar saldo nem preços de vendas anteriores.
DELETE /produtos/:id	Autenticado + CSRF	Só sem vínculos e com saldo zero; caso contrário 409.
GET /fornecedores	Autenticado	Lista fornecedores. Campos opcionais incluem CNPJ, razão/nome fantasia, endereço, contato e condições informativas.
POST /fornecedores	Autenticado + CSRF	Nome obrigatório e campos opcionais; cria em 201. CNPJ/CEP/telefone/e-mail validados.
PUT /fornecedores/:id	Autenticado + CSRF	Atualiza. Omissão preserva campo opcional; null ou vazio limpa.
DELETE /fornecedores/:id	Autenticado + CSRF	204; 404 se ausente, 409 se ligado a item.
GET /fornecedores/vinculos/:tipo	Autenticado	tipo é produtos ou materiais; lista associações.
PUT /fornecedores/vinculos/:tipo/:id	Autenticado + CSRF	fornecedores_ids substitui a lista; [] remove vínculos; sucesso 204.
GET /categorias-estoque?tipo=...	Autenticado	Filtro opcional produtos ou materiais.
POST /categorias-estoque	Autenticado + CSRF	tipo e nome; duplicidade no mesmo tipo retorna 409. Categoria é sugestão, não substitui o texto do item.

No cadastro de Material/Produto, saldo inicial positivo gera movimentação histórica na mesma transação. Materiais aceitam quantidade fracionária; Produto exige quantidade inteira. Valores monetários têm até duas casas.

Ordens de Serviço

GET /ordens-servico	Autenticado	Lista OS por ID; sem filtros/paginação.
GET /ordens-servico/:id	Autenticado	Detalhes, responsável e autor histórico quando disponível.
GET /ordens-servico/:id/materiais	Autenticado	Lista usos; OS inexistente 404.
POST /ordens-servico	Autenticado + CSRF	cliente_id, descricao_calcado, servico, valor; prazo_entrega, forma_pagamento, observacoes opcionais. Responsável é o usuário da sessão; status começa Aberta.
PUT /ordens-servico/:id	Autenticado + CSRF	Edita enquanto Aberta ou Em andamento; corpo inclui responsavel_id.
PUT /ordens-servico/:id/status	Autenticado + CSRF	Corpo {status}; sequência Aberta → Em andamento → Pronta → Entregue. Cancelar permitido até Pronta; estados finais não retrocedem.
POST /ordens-servico/:id/materiais	Autenticado + CSRF	material_id e quantidade_usada positiva. Registra uso e baixa saldo atomicamente; falta de saldo 409.
POST /ordens-servico/:id/materiais/:usoId/devolucoes	Autenticado + CSRF	quantidade e motivo; devolve apenas material não utilizado, limitado ao saldo não devolvido do uso.

Pagamento na OS, se informado, aceita pix, credito, debito ou dinheiro. A API recebe valor informado; não calcula preço da OS. Cancelamento da OS não repõe material automaticamente.

Vendas

GET /vendas	Autenticado	Lista vendas; itens consultados separadamente.
GET /vendas/:id	Autenticado	Consulta uma venda; ausente 404.
GET /vendas/:id/itens	Autenticado	Lista itens da venda.
POST /vendas	Autenticado + CSRF	forma_pagamento e itens [{produto_id,quantidade}]. Um ou mais itens; quantidade inteira positiva. Vendedor da sessão, preço do cadastro.
POST /vendas/:id/cancelamento	Autenticado + CSRF	itens_devolvidos [{item_venda_id,quantidade}], inclusive lista vazia. Cancela uma vez e devolve só o informado.

A venda, seus itens e as baixas de estoque são uma transação. O total deriva das quantidades e preços vigentes no cadastro, não de valores enviados pelo cliente. Não existe reembolso financeiro nem devolução posterior separada nesta etapa.

Movimentações, compras e importação de estoque

GET /movimentacoes-estoque	Autenticado	Histórico; filtro opcional material_id ou produto_id, nunca os dois.
GET /movimentacoes-estoque/historico-geral	Autenticado	Até 500 cadastros e movimentos, do mais recente.
GET /movimentacoes-estoque/:id	Autenticado	Consulta movimentação.
POST /movimentacoes-estoque	Autenticado + CSRF	tipo entrada/saida, quantidade positiva, motivo, exatamente um material_id ou produto_id. Saldo e movimento atualizados juntos.
POST /movimentacoes-estoque/:id/estorno	Autenticado + CSRF	motivo; estorna movimento manual integralmente uma vez.
GET /compras-estoque	Autenticado	Lista compras, fornecedor, data e linhas com quantidade/preço histórico.
POST /compras-estoque	Autenticado + CSRF	fornecedor_id e 1–100 itens; cada linha escolhe Material ou Produto, quantidade e preco_unitario. Transação única.
POST /estoque/importacoes	Autenticado + CSRF	Até 500 itens de Material/Produto; falha em uma linha desfaz o lote. Retorna registros criados em 201.

Movimentos manuais de saída não substituem consumo de OS ou venda. Para esses casos, use o endpoint do módulo de origem. Não há edição ou exclusão genérica de movimentação.

Configurações comerciais

GET /configuracoes/loja	Autenticado	Retorna endereço comercial.
PUT /configuracoes/loja	Administrador + CSRF	Corpo {endereco}; texto de até 500 caracteres. Vazio limpa.

Financeiro (somente Administrador)

GET /financeiro?inicio=&fim;=	Administrador	Consulta painel, resumo, movimentações e contas no período; datas YYYY-MM-DD opcionais.
GET /financeiro/:indicador	Administrador	Indicador faturamento, materiais, lucro ou impostos; período opcional. Impostos pode ser null.
POST /financeiro/despesas	Administrador + CSRF	categoria aluguel/energia/agua/funcionarios, descricao, valor, vencimento e total_parcelas opcional (1–120).
POST /financeiro/pagamentos	Administrador + CSRF	parcela_id, valor, forma_pagamento e pago_em opcional.
POST /financeiro/lancamentos/:id/estorno	Administrador + CSRF	Corpo motivo; cria estorno preservando o lançamento de origem.

Forma de pagamento aceita pix, credito, debito ou dinheiro. Impostos e lucro líquido dependem de definições ainda pendentes; o contrato documenta valores não definidos como null.

Atividades e notificações

GET /atividades	Autenticado	Filtros opcionais de, ate (AAAA-MM-DD), acao e funcionario_id. Administrador vê o histórico geral; Funcionário, ações próprias e eventos das OS atualmente atribuídas.
GET /notificacoes	Autenticado	Lista notificações destinadas ao usuário atual.
GET /notificacoes/nao-lidas	Autenticado	Retorna quantidade não lida.
POST /notificacoes/:id/lida	Autenticado + CSRF	Marca notificação própria como lida; 204. ID positivo; 404 se ausente, de outra pessoa ou já lida.
POST /notificacoes/lidas	Autenticado + CSRF	Marca todas as notificações próprias como lidas; 204.

5. Rotas documentadas como propostas

O documento de API também descreve ideias ainda não montadas no servidor. Não as trate como endpoints disponíveis: /perfil, /dashboard e POST /configuracoes/{cadastro}. Para confirmar o estado atual, consulte as rotas em backend/src/routes e as montagens em backend/server.ts.

6. Arquivos de referência

backend/server.ts	Prefixo, middlewares, sessões e montagem das rotas.
backend/src/routes/	Métodos e caminhos registrados em cada módulo.
backend/src/middlewares/csrf.ts	Geração e validação do token CSRF.
backend/src/config/sessao.ts	Cookie, armazenamento, duração e segredo da sessão.
backend/src/controllers/	Validação de entradas, respostas e regras dos handlers.
docs/api.md	Contrato documentado, situação e detalhes complementares.
docs/regras-de-negocio.md	Regras confirmadas, permissões e pendências do domínio.

Este PDF foi elaborado por leitura do código e documentação do projeto. Não foram executadas chamadas à API nem testes para produzir este guia.